CS 3002 Information Security

Fall 2026

1. Explain key concepts of information security such as design principles, cryptography, risk management,(1)
2. Discuss legal, ethical, and professional issues in information security (6)
3. Analyze real world scenarios, model them using security measures, and apply various security and risk management tools for achieving information security and privacy (2)
4. Identify appropriate techniques to tackle and solve problems of real life in the discipline of information security (3)
5. Understand issues related to ethics in the field of information security(8)



ISO/IEC 27001: 2013

Week # 2 – Lecture # 4, 5, 6

1.4 FUNDAMENTAL SECURITY DESIGN PRINCIPLES

Despite years of research and development, it has not been possible to develop security design and implementation techniques that systematically exclude security flaws and prevent all unauthorized actions. In the absence of such foolproof techniques, it is useful to have a set of widely agreed design principles that can guide the development of protection mechanisms. The National Centers of Academic Excellence in Information Assurance/Cyber Defense, which is jointly sponsored by the U.S. National Security Agency and the U. S. Department of Homeland Security, list the following as fundamental security design principles [NCAE13]:

- Economy of mechanism
- Fail-safe defaults
- Complete mediation
- Open design
- Separation of privilege
- Least privilege
- Least common mechanism
- Psychological acceptability
- Isolation
- Encapsulation
- Modularity
- Layering
- Least astonishment

Fundamental Security Design Principles

- **Economy of mechanism:** Keep security mechanisms as simple and straightforward as possible. This reduces the potential for errors and vulnerabilities that can arise from complex designs.
- **Fail-safe default:** The default action should be to deny access or secure access.
  - **For example:** If the firewall fails, let no traffic in
- **Complete mediation:** Ensure that every access to a resource is checked for authorization (usually check once).
  - **For example:** if you change the password it asks for an authentication
- **Open design:** This means the design of a security mechanism should be open rather than secret.
  - **For example:** Although encryption keys must be secret, encryption algorithms should be open to public investigation
- **Separation of privilege:** Multiple privilege attributes are required to achieve access to a restricted resource. (Access should not granted based on a single attribute)
  - **For example:** The use of multiple techniques, such as a password and a smart card, to authorize a user (Multifactor authentication)
- **Least privilege:** Grant users and processes only the minimum permissions necessary to perform their tasks.
  - **For example:** Role Based Access Control (RBAC) Model
- **Least common mechanism:** Sharing components or resources among different users or processes should be minimum. possible. This reduces the potential for one user's actions affecting another user's security.
  - **For example** In stack, if a user is sharing the file in user module, it should be in the user module

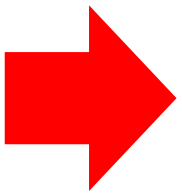
Fundamental Security Design Principles

- **Psychological acceptability:** Security measures should be designed in a way that it introduce a minimum hurdles to the user of the system.
  - **For example:** if person come to the campus it has to go through with the eye scan instead of access card
- **Isolation:** the system that has a critical data, process or resources must be isolated such that it restrict public access
  - **For example:** Multiple users in the same operating system, each user will manage its own account (isolated from each other) OR also example of VM
- **Encapsulation:** is a specific form of isolation based on object oriented functionality.
  - **For example:** if you are designing a password module the algorithm and methods of password will create in a class.
- **Modularity:** The security mechanism must of generated as separate and protected modules and using the modular architecture.
  - **For example: if an update is required then a specific module will update**
- **Layering:** refers to the use of multiple, overlapping protection approaches addressing the people, technology, and operational aspects of information systems
  - **For example:** Multiple barrier for the attacker if try to access the information (type of user, identification, firewall)
- **Least astonishment:** The user interface of the system must not amaze the user while accessing the secure system

1.6 COMPUTER SECURITY STRATEGY

We conclude this chapter with a brief look at the overall strategy for providing computer security. [LAMP04] suggests that a comprehensive security strategy involves three aspects:

- **Specification/policy:** What is the security scheme supposed to do?
- **Implementation/mechanisms:** How does it do it?
- **Correctness/assurance:** Does it really work?



ISO 9001:2015 employs the process approach, which incorporates the Plan-Do-Check-Act (PDCA) cycle and risk-based thinking. This means the organisation needs to:

1. determine required process inputs and expected outputs
2. assign responsibilities and authorities for processes
3. identify risks and opportunities for processes, and plan to address these

Computer Security Strategy

- **Security Policy**:- Formal statement of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources
- **Security Implementation:-** Involves four complementary courses of action:
    - Prevention
    - Detection
    - Response
    - Recovery
- **Assurance:-** Encompassing both system design and system implementation, assurance is an attribute of an information system that provides grounds for having confidence that the system operates such that the system's security policy is enforced
- **Evaluation**:- Evaluation Process of examining a computer product or system with respect to certain criteria Involves testing and may also involve formal analytic or mathematical techniques

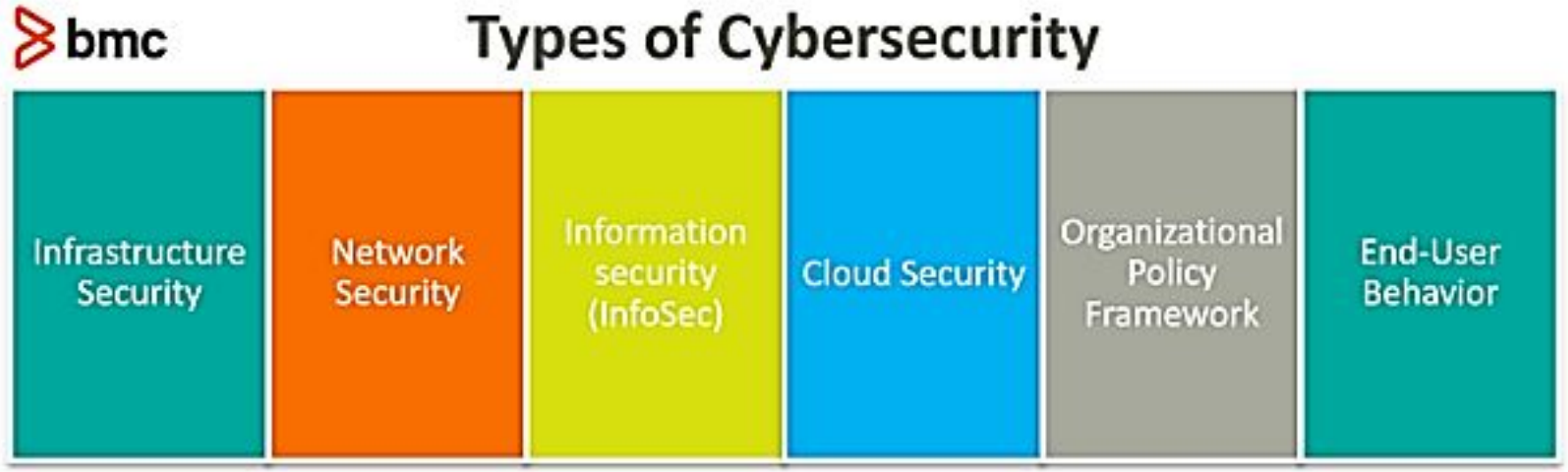
1.7 STANDARDS

- **National Institute of Standards and Technology:** NIST is a U.S. federal agency that deals with measurement science, standards, and technology related to U.S. government use and to the promotion of U.S. private sector innovation. Despite its national scope, NIST Federal Information Processing Standards (FIPS) and Special Publications (SP) have a worldwide impact.

- **ITU-T:** The International Telecommunication Union (ITU) is a United Nations agency in which governments and the private sector coordinate global telecom networks and services. The ITU Telecommunication Standardization Sector (ITU-T) is one of the three sectors of the ITU. ITU-T's mission is the production of standards covering all fields of telecommunications. ITU-T standards are referred to as Recommendations.

- **Internet Society:** ISOC is a professional membership society with worldwide organizational and individual membership. It provides leadership in addressing issues that confront the future of the Internet, and is the organization home for the groups responsible for Internet infrastructure standards, including the Internet Engineering Task Force (IETF) and the Internet Architecture Board (IAB). These organizations develop Internet standards and related specifications, all of which are published as Requests for Comments (RFCs).

- **ISO:** The International Organization for Standardization (ISO) is a worldwide federation of national standards bodies from more than 140 countries. ISO is a nongovernmental organization that promotes the development of standardization and related activities with a view to facilitating the international exchange of goods and services, and to developing cooperation in the spheres of intellectual, scientific, technological, and economic activity. ISO's work results in international agreements that are published as International Standards.

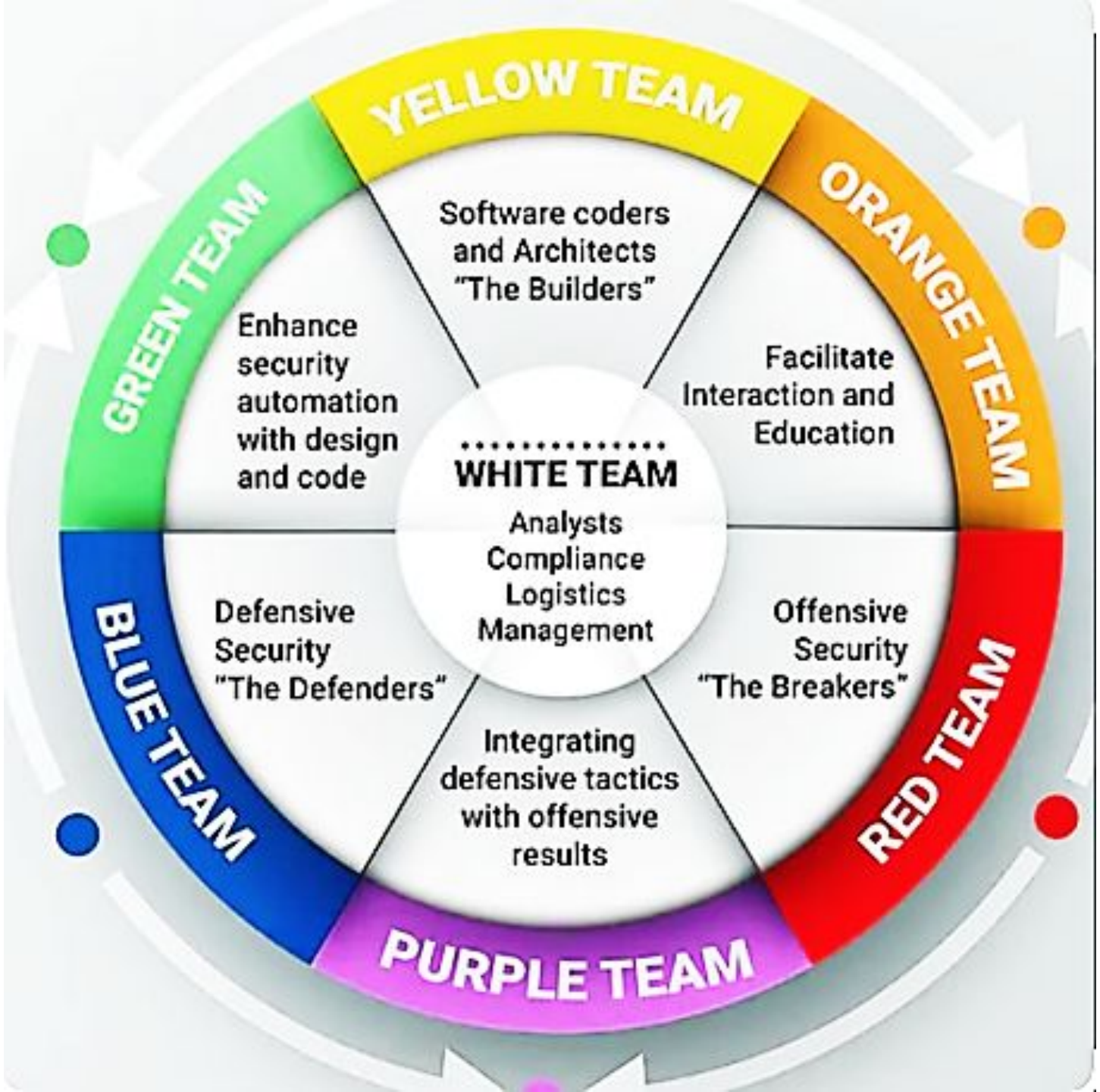


- Physical Security
- Access Security of Infrastructure
- Information security (including non digital)
- OS security
- Application Security
- Network Security

- Identification of Assets
- Identify Vulnerabilities
  - (CIA + Authentication + Auditable)
- Risk Assessment Possible Threats
- Known and possible Attacks
- Test and Implement known Countermeasures
  - Based on community Best Practices
- Governmental and Community based efforts
  - Groups (Meetups) + CERTs + Conferences + Certifications

InfoSec Practice

- Identification of Assets
- Identify Vulnerabilities
  - (CIA + Authentication + Auditable)
- Risk Assessment Possible Threats
- Known and possible Attacks
- Test and Implement known Countermeasures
  - Based on community Best Practices
- Governmental and Community based efforts
  - Groups (Meetups) + CERTs + Conferences + Certifications


YELLOW TEAM
Software coders and Architects "The Builders"
ORANGE TEAM
Facilitate Interaction and Education
GREEN TEAM
Enhance security automation with design and code
WHITE TEAM
Analysts
Compliance
Logistics
Management
BLUE TEAM
Defensive Security "The Defenders"
RED TEAM
Offensive Security "The Breakers"
PURPLE TEAM
Integrating defensive tactics with offensive results

Possible Coverage before Midterm # 1

Topics from Chapter # 2, Chapter # 20 and Chapter # 21

2.1 **Confidentiality with Symmetric Encryption**
- Symmetric Encryption
- Symmetric Block Encryption Algorithms
- Stream Ciphers

2.2 **Message Authentication and Hash Functions**
- Authentication Using Symmetric Encryption
- Message Authentication without Message Encryption
- Secure Hash Functions
- Other Applications of Hash Functions

2.3 **Public-Key Encryption**
- Public-Key Encryption Structure
- Applications for Public-Key Cryptosystems
- Requirements for Public-Key Cryptography
- Asymmetric Encryption Algorithms

2.4 **Digital Signatures and Key Management**
- Digital Signature
- Public-Key Certificates
- Symmetric Key Exchange Using Public-Key Encryption
- Digital Envelopes

20.2 **Data Encryption Standard**
- Data Encryption Standard
- Triple DES

20.3 **Advanced Encryption Standard**
- Overview of the Algorithm
- Algorithm Details

21.4 **The RSA Public-Key Encryption Algorithm**
- Description of the Algorithm
- The Security of RSA

CHAPTER 2

CRYPTOGRAPHIC TOOLS

2.1 Confidentiality with Symmetric Encryption

Symmetric Encryption
Symmetric Block Encryption Algorithms
Stream Ciphers

2.1 CONFIDENTIALITY WITH SYMMETRIC ENCRYPTION

Encryption is the process of converting information or data into a code, especially to prevent unauthorized access.

Symmetric Encryption

Symmetric encryption, also referred to as conventional encryption or single-key encryption, was the only type of encryption in use prior to the introduction of public-key encryption in the late 1970s. Countless individuals and groups, from Julius Caesar to the German U-boat force to present-day diplomatic, military, and commercial users, have used symmetric encryption for secret communication. It remains the more widely used of the two types of encryption.

2.1 CONFIDENTIALITY WITH SYMMETRIC ENCRYPTION

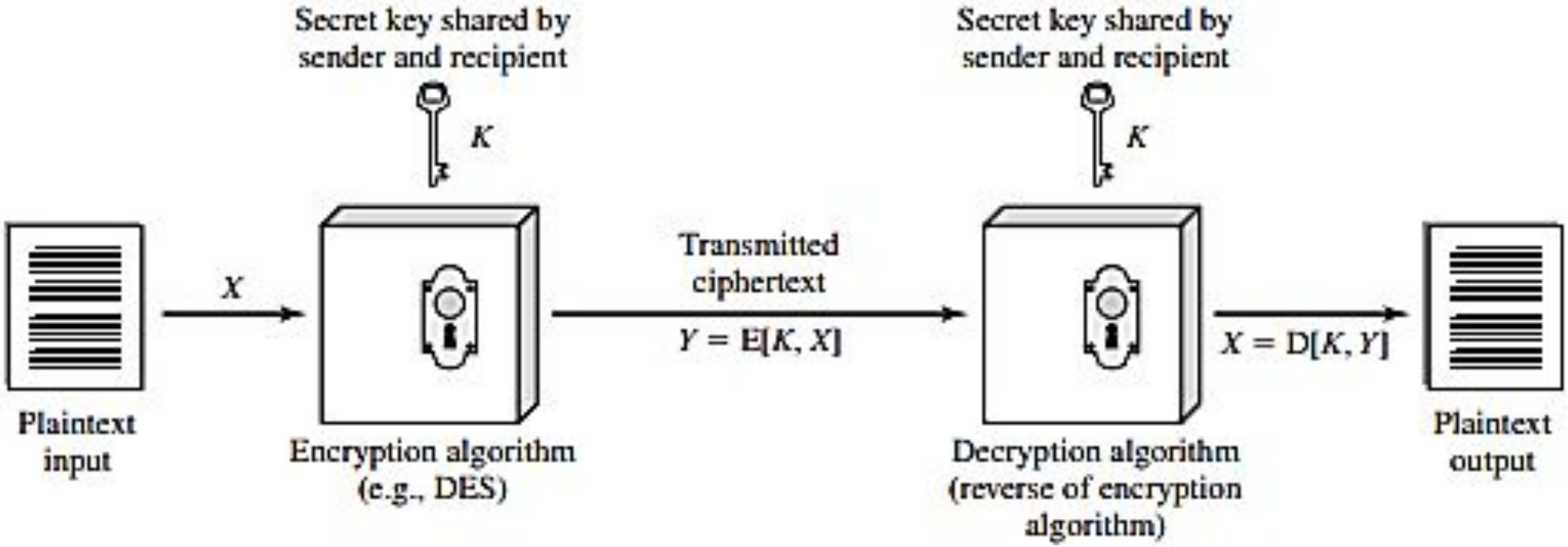


Figure 2.1 Simplified Model of Symmetric Encryption

2.1 CONFIDENTIALITY WITH SYMMETRIC ENCRYPTION

A symmetric encryption scheme has five ingredients (see Figure 2.1):

- **Plaintext:** This is the original message or data that is fed into the algorithm as input.
- **Encryption algorithm:** The encryption algorithm performs various substitutions and transformations on the plaintext.
- **Secret key:** The secret key is also input to the encryption algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.
- **Ciphertext:** This is the scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different ciphertexts.
- **Decryption algorithm:** This is essentially the encryption algorithm run in reverse. It takes the ciphertext and the secret key and produces the original plaintext.

2.1 CONFIDENTIALITY WITH SYMMETRIC ENCRYPTION

There are two requirements for secure use of symmetric encryption:

1. We need a strong encryption algorithm. At a minimum, we would like the algorithm to be such that an opponent who knows the algorithm and has access to one or more ciphertexts would be unable to decipher the ciphertext or figure out the key. This requirement is usually stated in a stronger form: The opponent should be unable to decrypt ciphertext or discover the key even if he or she is in possession of a number of ciphertexts together with the plaintext that produced each ciphertext.
2. The sender and receiver must have obtained copies of the secret key in a secure fashion and must keep the key secure. If someone can discover the key and knows the algorithm, all communication using this key is readable.

There are two general approaches to attacking a symmetric encryption scheme.

Attacking a Symmetric Encryption Scheme (1)

- **Brute-force attack** is to try every possible key on a piece of cipher text until an intelligible translation into plaintext is obtained.
  - On average, half of all possible keys must be tried to achieve success. That is, if there are *x* different keys, on average an attacker would discover the actual key after *x*/2 tries.
  - This means size of key has a great impact of breaking the symmetric Encryption schedule. Larger the key the more time it will takes to try all possible key combinations.

Table 2.2 **Average Time Required for Exhaustive Key Search**

Key Size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/μs	Time Required at 10^{13} decryptions/μs
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	$2^{55}\ \mu s = 1.125$ years	1 hour
128	AES	$2^{128} \approx 3.4 \times 10^{38}$	$2^{127}\ \mu s = 5.3 \times 10^{21}$ years	5.3×10^{17} years
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	$2^{167}\ \mu s = 5.8 \times 10^{33}$ years	5.8×10^{29} years
192	AES	$2^{192} \approx 6.3 \times 10^{57}$	$2^{191}\ \mu s = 9.8 \times 10^{40}$ years	9.8×10^{36} years
256	AES	$2^{256} \approx 1.2 \times 10^{77}$	$2^{255}\ \mu s = 1.8 \times 10^{60}$ years	1.8×10^{56} years

Attacking a Symmetric Encryption Scheme (1)

- **Brute-force attack** is to try every possible key on a piece of cipher text until an intelligible translation into plaintext is obtained.
  - On average, half of all possible keys must be tried to achieve success. That is, if there are *x* different keys, on average an attacker would discover the actual key after *x*/2 tries.
  - This means size of key has a great impact of breaking the symmetric Encryption schedule. Larger the key the more time it will takes to try all possible key combinations.
- More information about plain text is needed **to break in less time** (i.e. trying half the keys):
  - Language of the plain text. This make it easy to recognize the result.
  - If the text message has been compressed before encryption, then recognition is more difficult.
  - A numerical file that has been compressed, the problem becomes even more difficult.

Attacking a Symmetric Encryption Scheme (2)

- **Cryptanalysis**. Cryptanalysis refers to the process of analyzing information systems in order to understand hidden aspects of the systems.

- Cryptanalysis is used to breach cryptographic security systems and gain access to the contents of encrypted messages, even if the cryptographic key is unknown.

- This attacks rely on the nature of the algorithm plus perhaps some knowledge of the general characteristics of
  - the plaintext, or
  - some knowledge of some plaintext-ciphertext pairs.

- This type of attack exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or to deduce the key being used.
  - If the attack succeeds in deducing the key, the effect is catastrophic: All future and past messages encrypted with that key are compromised.

Symmetric Block Encryption Algorithms

- Types of Symmetric Encryption
  - Block Ciphers
  - Stream Ciphers
- Symmetric Block Encryption Algorithms
  - DES and AES
  - Weaknesses of DES and Triple-DES
- Data Encryption Standard (DES) Algorithms

Types of Symmetric Encryption

Symmetric Block Encryption Algorithms

The most commonly used symmetric encryption algorithms are block ciphers. A block cipher processes the plaintext input in fixed-size blocks and produces a block of ciphertext of equal size for each plaintext block. The algorithm processes longer plaintext amounts as a series of fixed-size blocks. The most important symmetric algo-

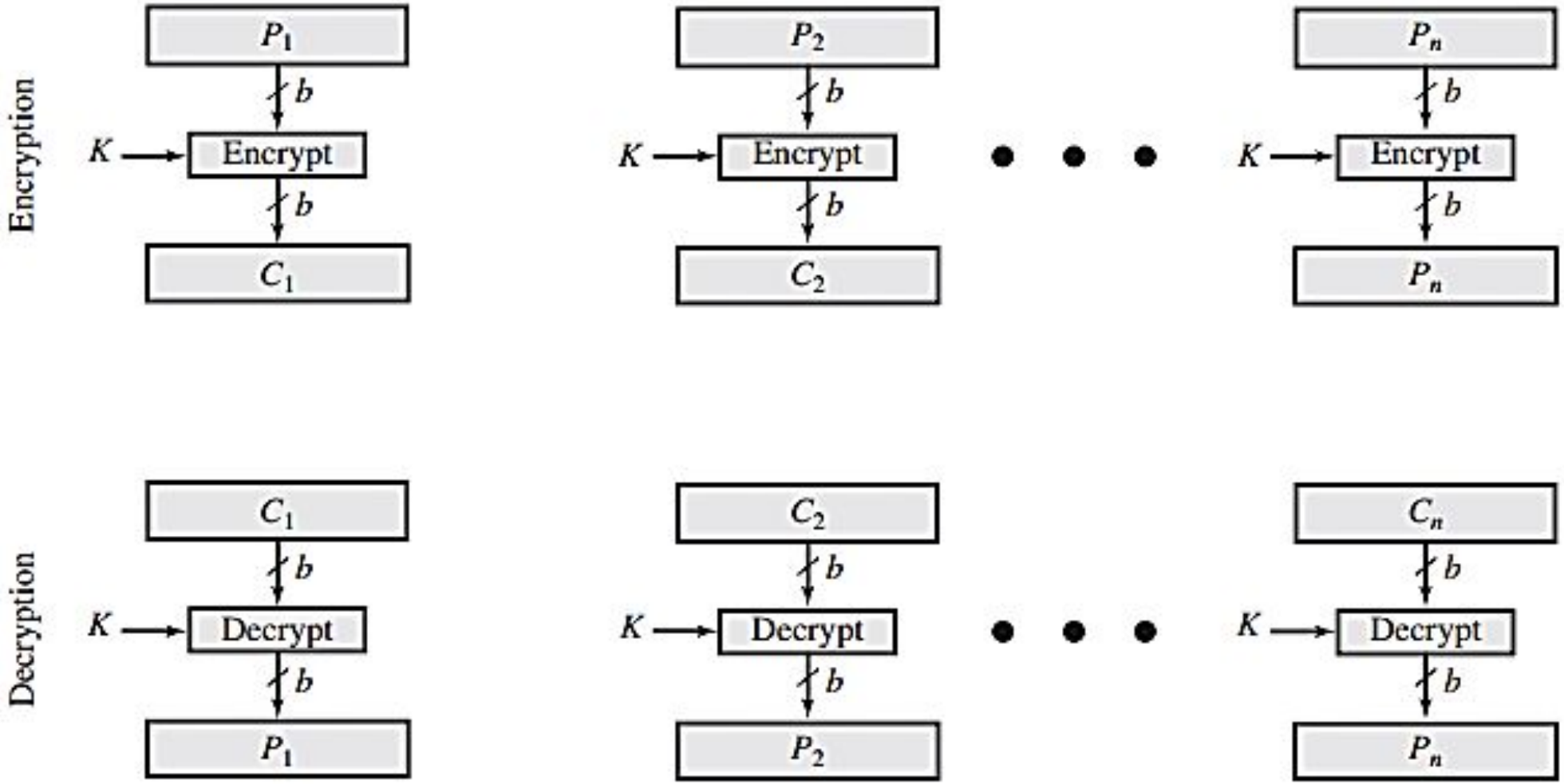
Stream Ciphers

A *block cipher* processes the input one block of elements at a time, producing an output block for each input block. A *stream cipher* processes the input elements continuously, producing output one element at a time, as it goes along. Although block ciphers are far more common, there are certain applications in which a stream cipher is more appropriate.

Application of Block and stream cipher

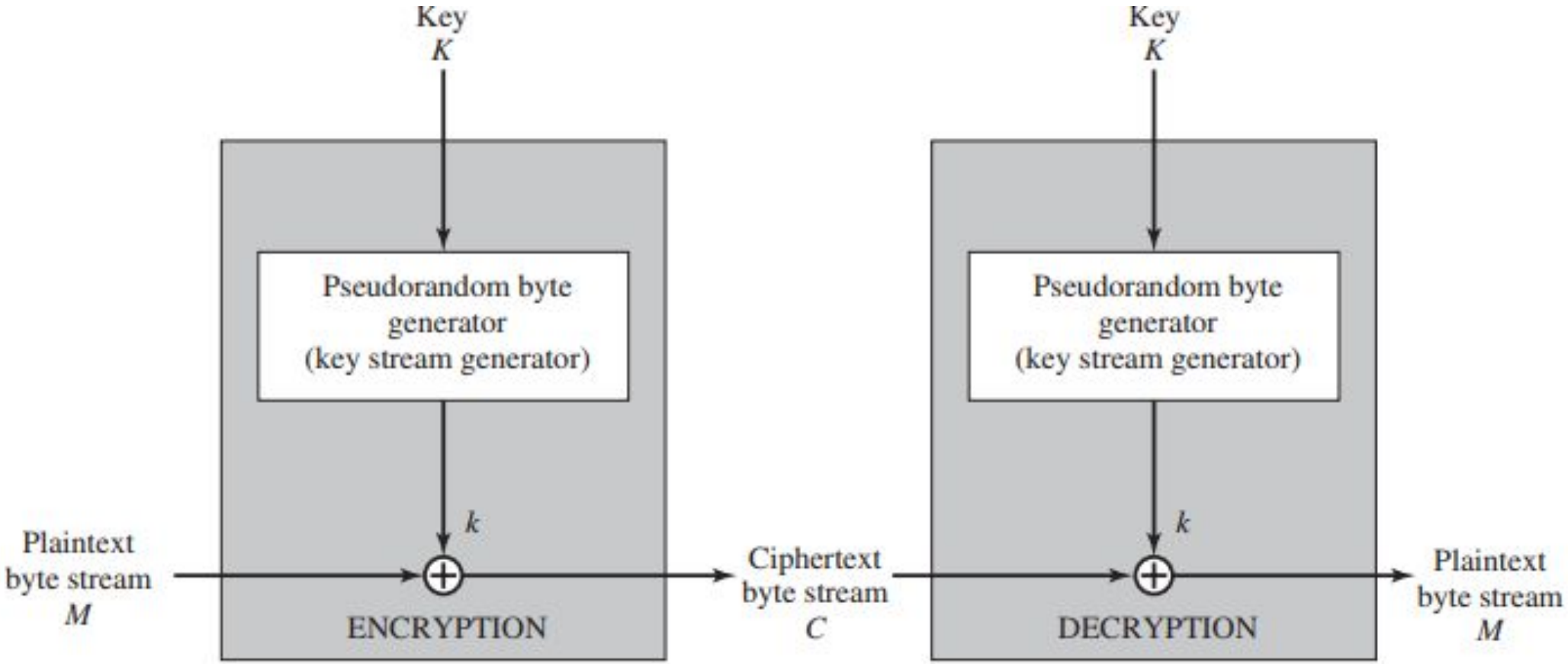
- For applications that deal with blocks of data, such as:
  - File transfer
  - E-mail
  - Database
  - File and disk encryption

- For applications that require encryption/decryption of a stream of data, such as over a data communications channel or a browser/Web link, a stream cipher might be the better alternative.



(a) Block cipher encryption (electronic codebook mode)

Figure 2.2 Types of Symmetric Encryption



(b) Stream encryption

Figure 2.2 Types of Symmetric Encryption

Symmetric Block Encryption Algorithms

The most important symmetric algorithms, all of which are block ciphers, are the Data Encryption Standard (DES), triple DES, and the Advanced Encryption Standard (AES); see Table 2.1. This subsection provides an overview of these algorithms.

Table 2.1 **Comparison of Three Popular Symmetric Encryption Algorithms**

	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

DES = Data Encryption Standard
AES = Advanced Encryption Standard

Concerns about the strength of DES Algorithm (1)

Concerns about the strength of DES fall into two categories: concerns about the algorithm itself, and concerns about the use of a 56-bit key. The first concern refers to the possibility that cryptanalysis is possible by exploiting the characteristics of the DES algorithm. Over the years, there have been numerous attempts to find and exploit weaknesses in the algorithm, making DES the most-studied encryption algorithm in existence. Despite numerous approaches, no one has so far reported a fatal weakness in DES.

A more serious concern is key length. With a key length of 56 bits, there are 2^{56} possible keys, which is approximately 7.2×10^{16} keys. Given the speed of commercial off-the-shelf processors, this key length is woefully inadequate. A paper from Seagate Technology [SEAG08] suggests that a rate of one billion (10^9) key combinations per second is reasonable for today's multicore computers. Recent offerings confirm this.

Concerns about the strength of DES Algorithm (2)

Both Intel and AMD now offer hardware-based instructions to accelerate the use of AES. Tests run on a contemporary multicore Intel machine resulted in an encryption rate of about half a billion encryptions per second [BASU12]. Another recent analysis suggests that with contemporary supercomputer technology, a rate of 10^{13} encryptions/s is reasonable [AROR12].

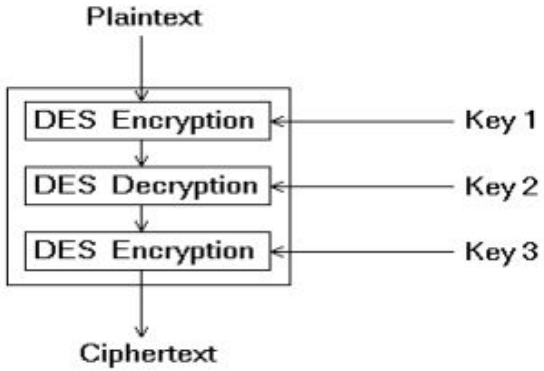
Table 2.2 **Average Time Required for Exhaustive Key Search**

Key Size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/μs	Time Required at 10^{13} decryptions/μs
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	$2^{55}\ \mu s = 1.125$ years	1 hour
128	AES	$2^{128} \approx 3.4 \times 10^{38}$	$2^{127}\ \mu s = 5.3 \times 10^{21}$ years	5.3×10^{17} years
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	$2^{167}\ \mu s = 5.8 \times 10^{33}$ years	5.8×10^{29} years
192	AES	$2^{192} \approx 6.3 \times 10^{57}$	$2^{191}\ \mu s = 9.8 \times 10^{40}$ years	9.8×10^{36} years
256	AES	$2^{256} \approx 1.2 \times 10^{77}$	$2^{255}\ \mu s = 1.8 \times 10^{60}$ years	1.8×10^{56} years

Addressing the small key size of DES Algorithm

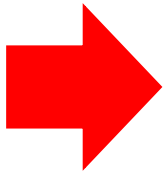
TRIPLE DES The life of DES was extended by the use of triple DES (3DES), which involves repeating the basic DES algorithm three times, using either two or three unique keys, for a key size of 112 or 168 bits.

3DES has two attractions that assure its widespread use over the next few years. First, with its 168-bit key length, it overcomes the vulnerability to brute-force attack of DES. Second, the underlying encryption algorithm in 3DES is the same as in DES. This algorithm has been subjected to more scrutiny than any other encryption algorithm over a longer period of time, and no effective cryptanalytic attack based on the algorithm rather than brute force has been found. Accordingly, there is a high level of confidence that 3DES is very resistant to cryptanalysis. If security were the only consideration, then 3DES would be an appropriate choice for a standardized encryption algorithm for decades to come.



Drawback of DES Algorithm

The principal drawback of 3DES is that the algorithm is relatively sluggish in software. The original DES was designed for mid-1970s hardware implementation and does not produce efficient software code. 3DES, which requires three times as many calculations as DES, is correspondingly slower. A secondary drawback is that both DES and 3DES use a 64-bit block size. For reasons of both efficiency and security, a larger block size is desirable.



ADVANCED ENCRYPTION STANDARD Because of its drawbacks, 3DES is not a reasonable candidate for long-term use. As a replacement, NIST in 1997 issued a call for proposals for a new Advanced Encryption Standard (AES), which should have a security strength equal to or better than 3DES and significantly improved efficiency. In addition to these general requirements, NIST specified that AES must be a symmetric block cipher with a block length of 128 bits and support for key lengths of 128, 192, and 256 bits. Evaluation criteria included security, computational efficiency, memory requirements, hardware and software suitability, and flexibility.

Data Encryption Standard (DES)

Coverage from slides provided by Course Coordinator

DES is a block cipher, as shown in Figure 6.1.

Figure 6.1 ***Encryption and decryption with DES***



Data Encryption Standard (DES)

- The DES algorithm can be described as follows.
  - The plaintext is 64 bits in length
  - The key is 56 bits in length
  - There are 16 rounds of processing.
  - From the original 56-bit key, 16subkeys are generated (ki= 48 bit)
    - one of which is used for each round.

- **Encryption process:**
  1. Permutation performed on the input block
  2. Generation of round keys
  3. Performing 16 identical rounds
     a. Substitution
     b. Permutation
  4. Inverse permutation to step 1

- **Decryption process:**
  - Use the ciphertext as input to the DES algorithm, but use the sub-keys Ki in reverse order.
  - That is, use K16 on the first iteration, K15 on the second iteration, and so on until K1 is used on the sixteenth and last iteration.

Figure 6.2 *General structure of DES*

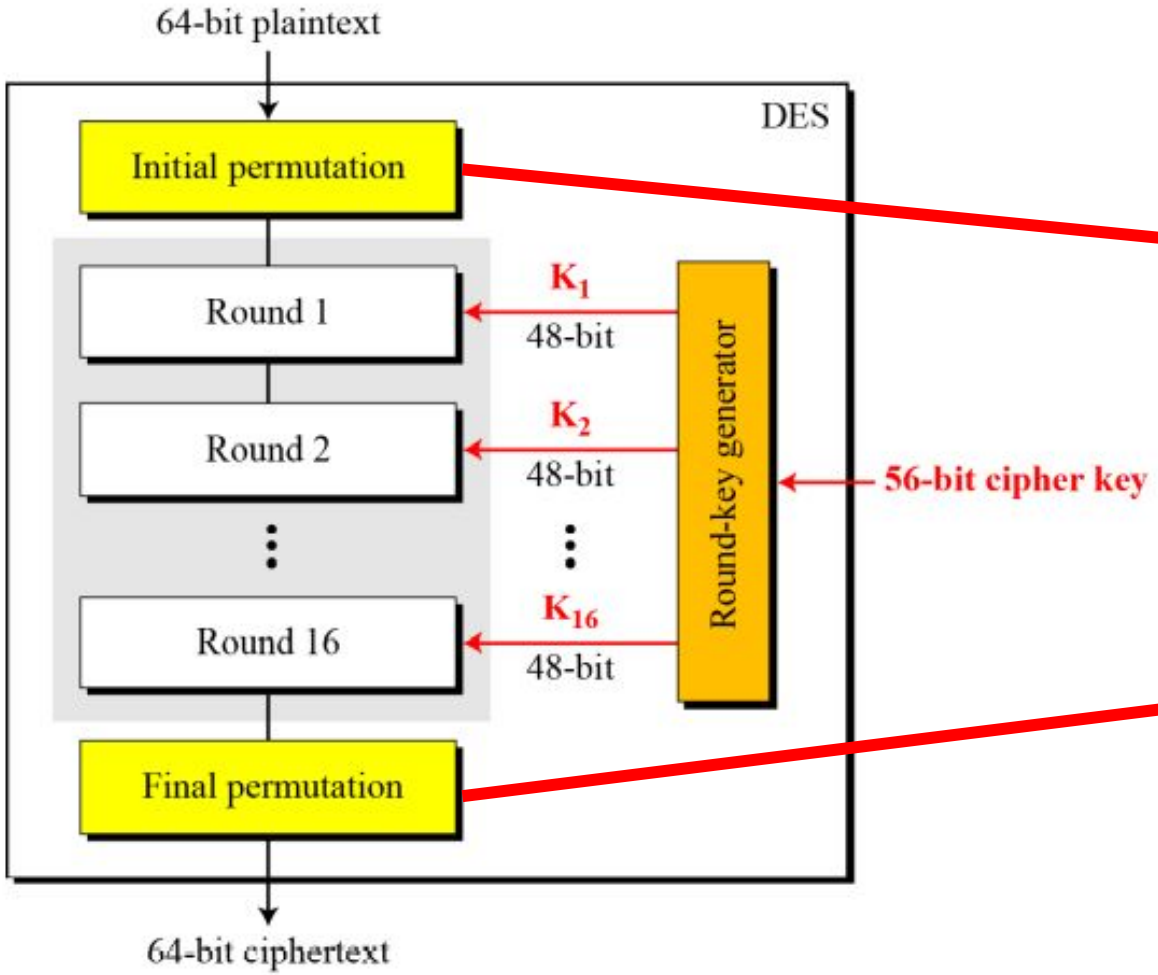
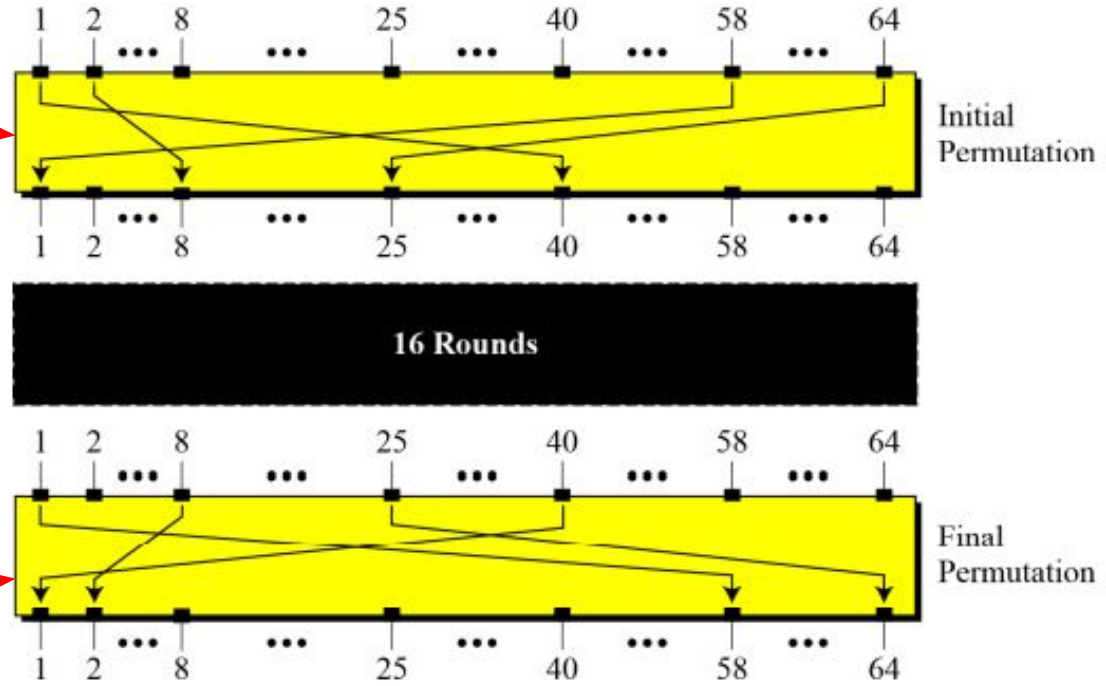


Figure 6.3 *Initial and final permutation steps in DES*



Initial Permutation								*Final Permutation*							
58	50	42	34	26	18	10	02	40	08	48	16	56	24	64	32
60	52	44	36	28	20	12	04	39	07	47	15	55	23	63	31
62	54	46	38	30	22	14	06	38	06	46	14	54	22	62	30
64	56	48	40	32	24	16	08	37	05	45	13	53	21	61	29
57	49	41	33	25	17	09	01	36	04	44	12	52	20	60	28
59	51	43	35	27	19	11	03	35	03	43	11	51	19	59	27
61	53	45	37	29	21	13	05	34	02	42	10	50	18	58	26
63	55	47	39	31	23	15	07	33	01	41	09	49	17	57	25

The initial and final permutations are straight P-boxes that are inverses of each other. They have no cryptography significance in DES. Both permutations are keyless and predetermined.

Rule: In the initial permutation, the 58th bit in the input becomes the first bit in the output. Similarly, in the final permutation, the first bit in the input becomes the 58th bit in the output.

DES uses 16 rounds. Each round of DES is a Feistel cipher.

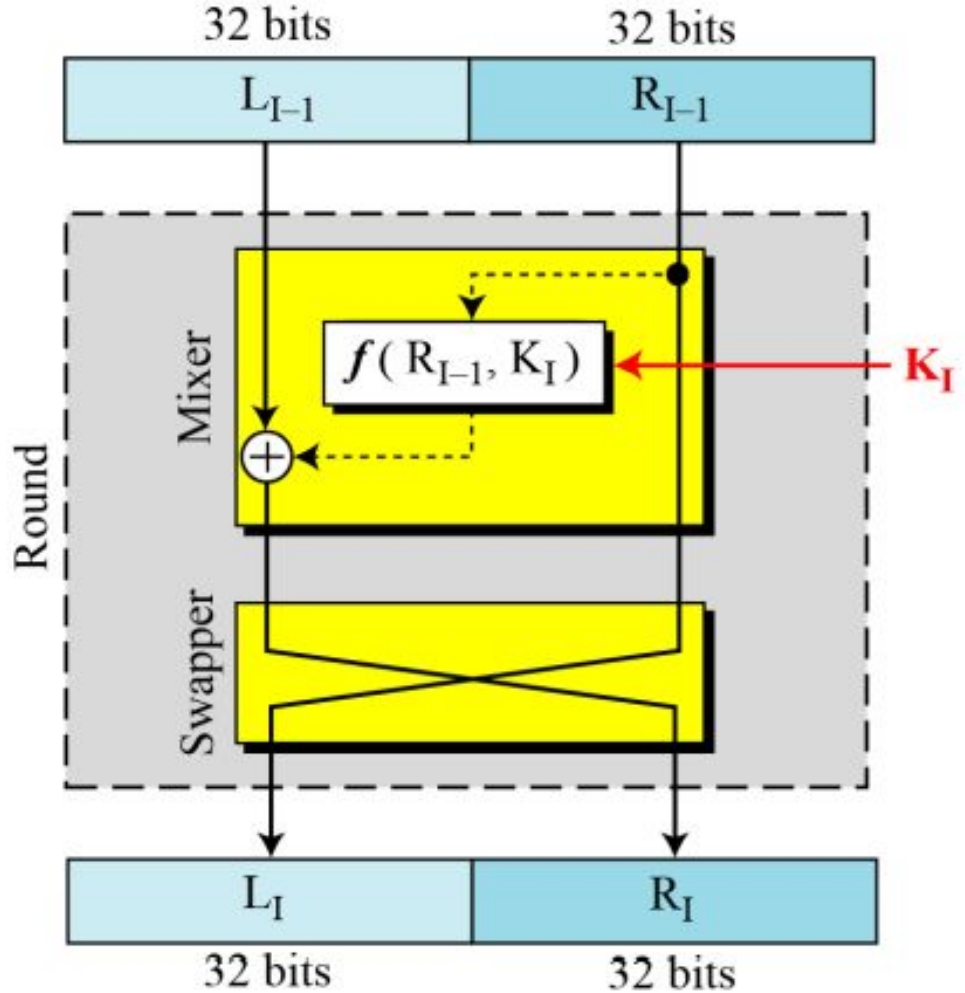


Figure 6.4
A round in DES (encryption site)

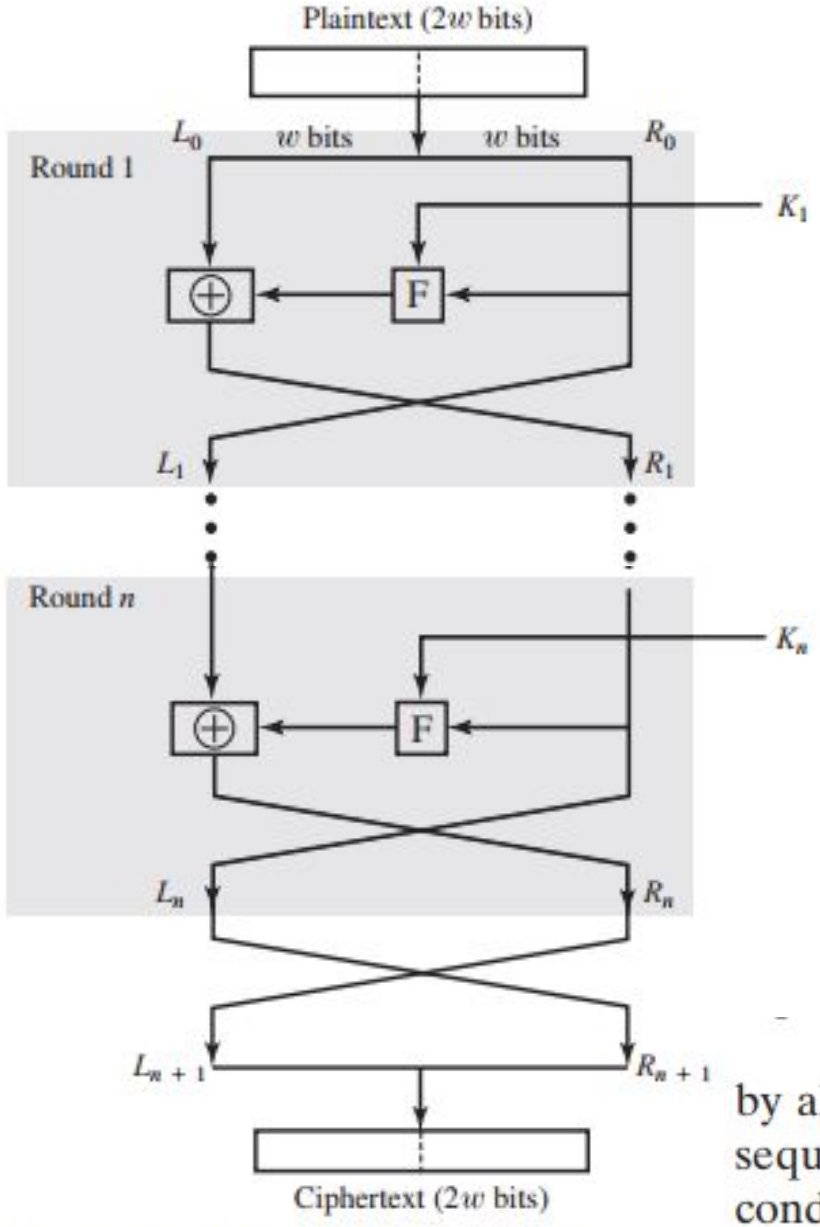
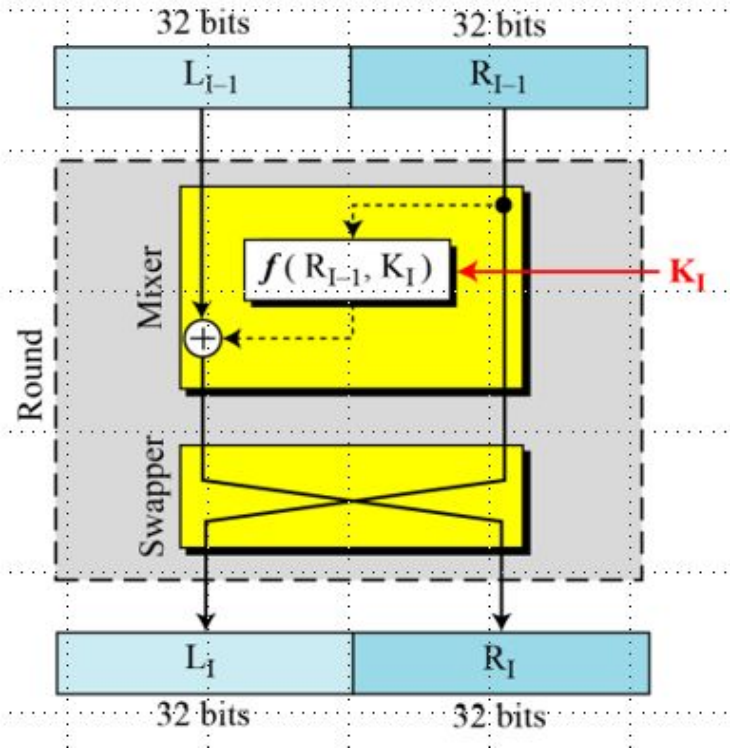


Figure 20.1 **Classical Feistel Network**

Textbook page 631-631



The Feistel structure is a particular example of the more general structure used by all symmetric block ciphers. In general, a symmetric block cipher consists of a sequence of rounds, with each round performing substitutions and permutations conditioned by a secret key value. The exact realization of a symmetric block cipher

Feistel Cipher Structure

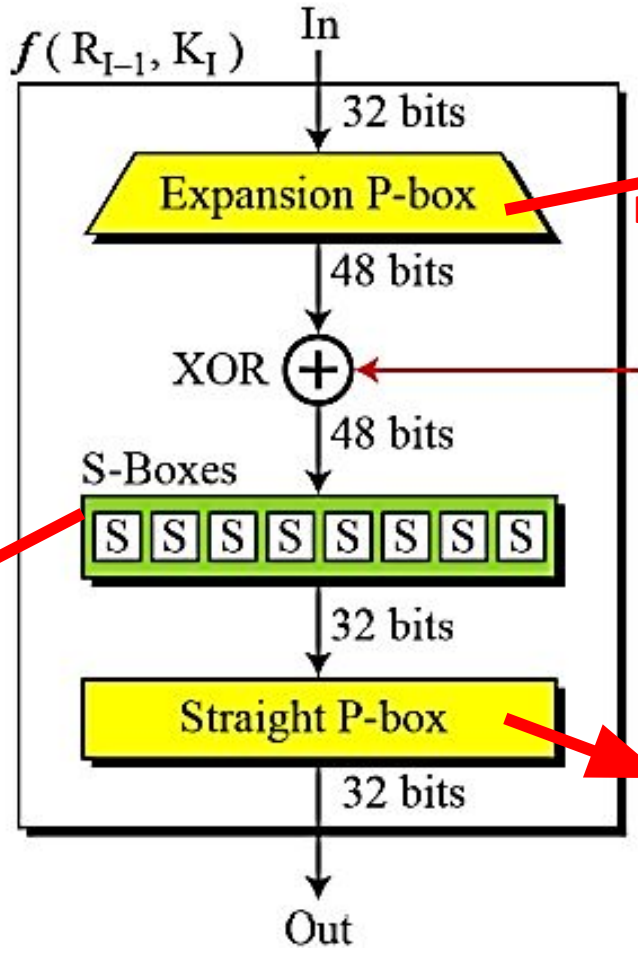
Textbook page 631-631

Many symmetric block encryption algorithms, including DES, have a structure first described by Horst Feistel of IBM in 1973 [FEIS73] and shown in Figure 20.1. The inputs to the encryption algorithm are a plaintext block of length $2w$ bits and a key K. The plaintext block is divided into two halves, L_0 and R_0. The two halves of the data pass through n rounds of processing and then combine to produce the ciphertext block. Each round i has as inputs L_{i-1} and R_{i-1}, derived from the previous round, as well as a subkey K_i, derived from the overall K. In general, the subkeys K_i are different from K and from each other, and are generated from the key by a subkey generation algorithm.

All rounds have the same structure. A substitution is performed on the left half of the data. This is done by applying a *round function* F to the right half of the data and then taking the exclusive-OR (XOR) of the output of that function and the left half of the data. The round function has the same general structure for each round but is parameterized by the round subkey K_i. Following this substitution, a permutation is performed that consists of the interchange of the two halves of the data.

The heart of DES is the DES function. The DES function applies a 48-bit key to the rightmost 32 bits to produce a 32-bit output.

Figure 6.5
DES function

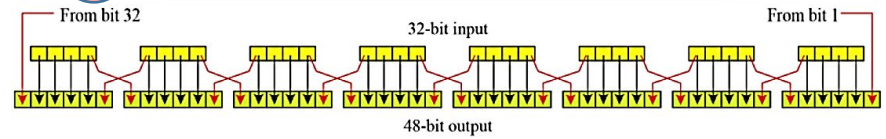


By duplicating bits

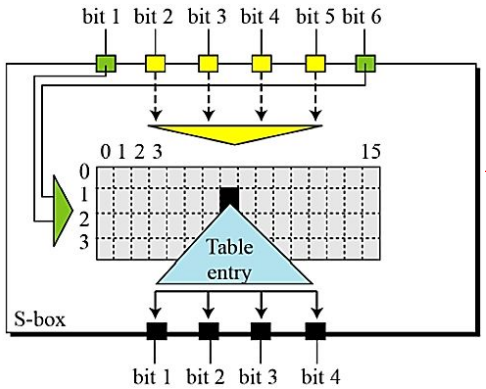
K_I (48 bits)

Table 6.6 *Expansion P-box table*

32	01	02	03	04	05
04	05	06	07	08	09
08	09	10	11	12	13
12	13	14	15	16	17
16	17	18	19	20	21
20	21	22	23	24	25
24	25	26	27	28	29
28	29	31	31	32	01



Details on next slide



Details on next slide

Table 6.11 *Straight permutation table*

16	07	20	21	29	12	28	17
01	15	23	26	05	18	31	10
02	08	24	14	32	27	03	09
19	13	30	06	22	11	04	25

Expansion P-box

Since R_{I-1} is a 32-bit input and K_I is a 48-bit key, we first need to expand R_{I-1} to 48 bits.

Figure 6.6 *Expansion permutation*

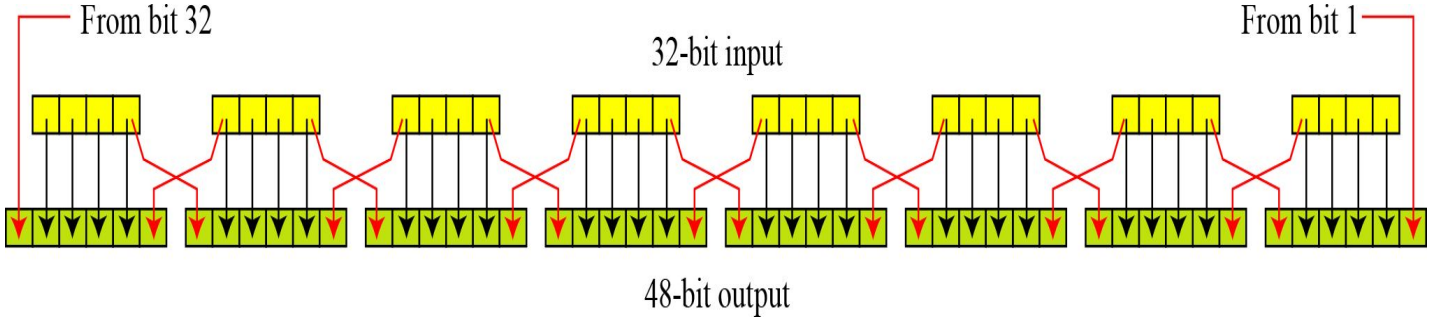


Table 6.2 *Expansion D-box table*

32	01	02	03	04	05
04	05	06	07	08	09
08	09	10	11	12	13
12	13	14	15	16	17
16	17	18	19	20	21
20	21	22	23	24	25
24	25	26	27	28	29
28	29	31	31	32	01

Note: The number of output ports is 48, but the value range is only 1 to 32. Some of the inputs go to more than one output.

S-Boxes (Substitution Boxes)

The S-boxes do the real mixing (confusion). DES uses 8 S-boxes, each with a 6-bit input and a 4-bit output. See Figure 6.7.

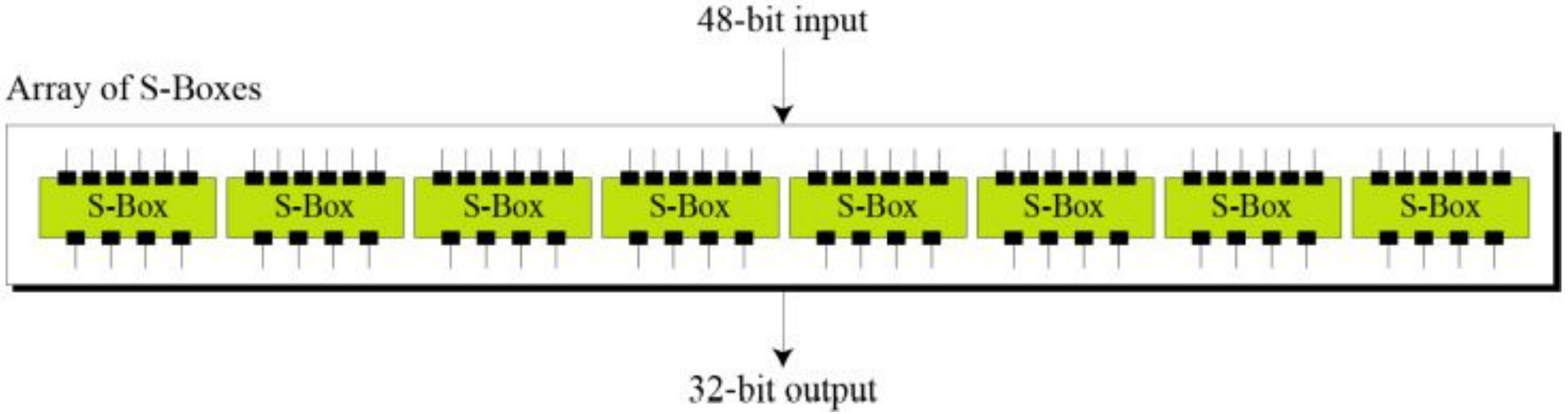
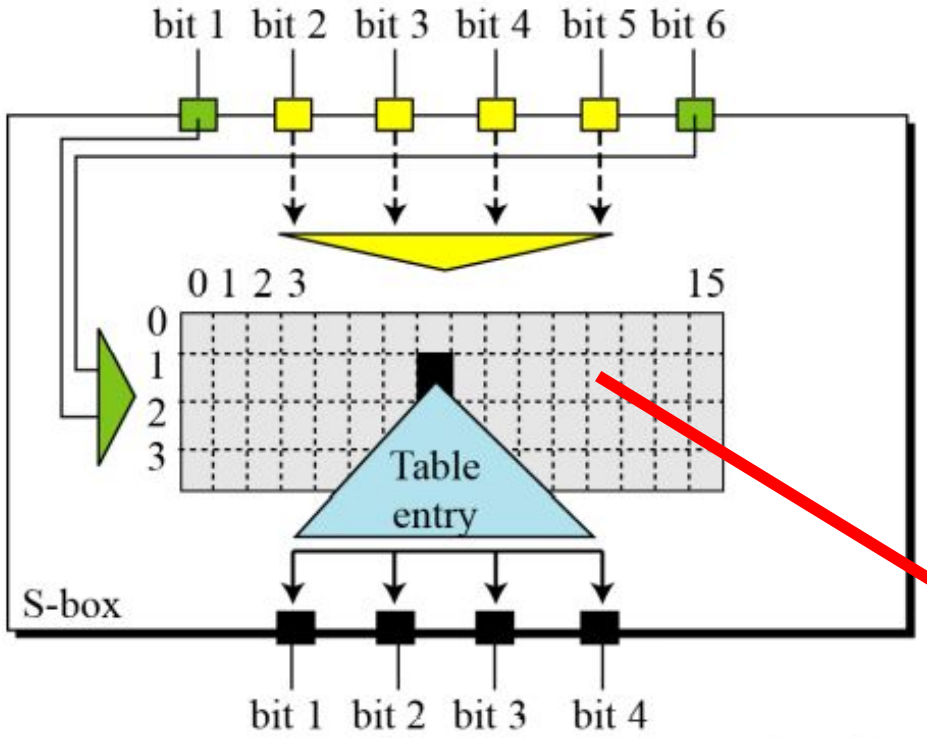


Figure 6.7 ***S-boxes***

* There are 8 S-Boxes. Each one has its own table.

Figure 6.8 *S-box rule*

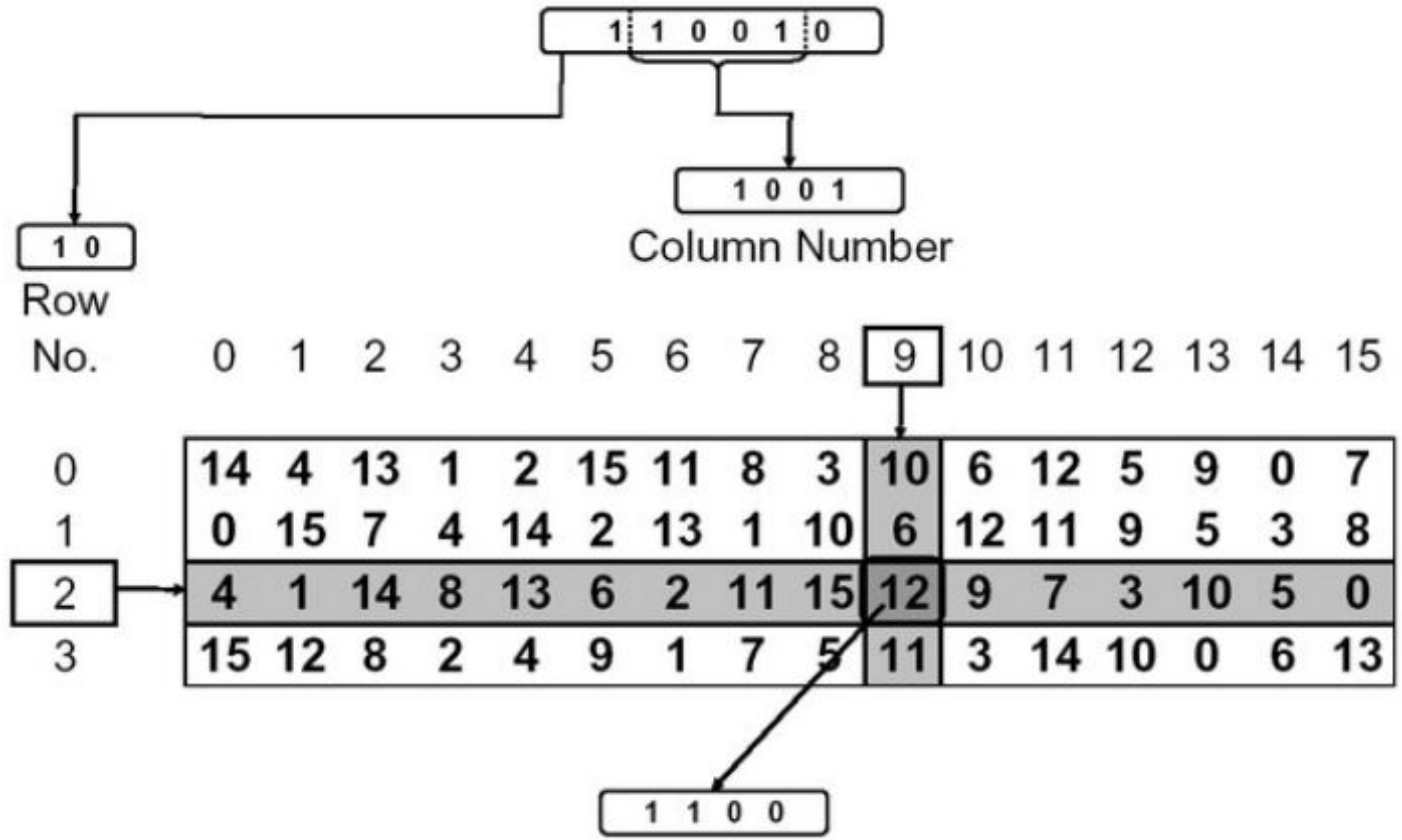


- Each 8-S-boxes has a 6-bit input and a 4-bit output.
- The values of the inputs (row number and column number)
- **Each 6-bit piece uses as an address in the S-boxes where the first and last bits are used to address the ith row and the middle four bits to address the jth column in the S-boxes.**
- **The output of each S-box is 4-bit length piece. The output of all eight S-boxes is then combined into 32 bit section**

* Each S-box has its own table.

Table 6.3 *S-box 1*

	0	*1*	*2*	*3*	*4*	*5*	*6*	*7*	*8*	*9*	*10*	*11*	*12*	*13*	*14*	*15*
0	14	04	13	01	02	15	11	08	03	10	06	12	05	09	00	07
1	00	15	07	04	14	02	13	10	03	06	12	11	09	05	03	08
2	04	01	14	08	13	06	02	11	15	12	09	07	03	10	05	00
3	15	12	08	02	04	09	01	07	05	11	03	14	10	00	06	13


1 1 0 0 1 0
1 0 0 1
Column Number
1 0
Row
No.
0 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15
0
1
2
3
14 4 13 1 2 15 11 8 3 10 6 12 5 9 0 7
0 15 7 4 14 2 13 1 10 6 12 11 9 5 3 8
4 1 14 8 13 6 2 11 15 12 9 7 3 10 5 0
15 12 8 2 4 9 1 7 5 11 3 14 10 0 6 13
1 1 0 0

Key Generation

The round-key generator creates sixteen 48-bit keys out of a 56-bit cipher key.

Shifting

Rounds	Shift
1, 2, 9, 16	one bit
Others	two bits

Table 6.12 *Parity-bit drop table*

57	49	41	33	25	17	09	01
58	50	42	34	26	18	10	02
59	51	43	35	27	19	11	03
60	52	44	36	63	55	47	39
31	23	15	07	62	54	46	38
30	22	14	06	61	53	45	37
29	21	13	05	28	20	12	04

Table 6.14 *Key-compression table*

14	17	11	24	01	05	03	28
15	06	21	10	23	19	12	04
26	08	16	07	27	20	13	02
41	52	31	37	47	55	30	40
51	45	33	48	44	49	39	56
34	53	46	42	50	36	29	32

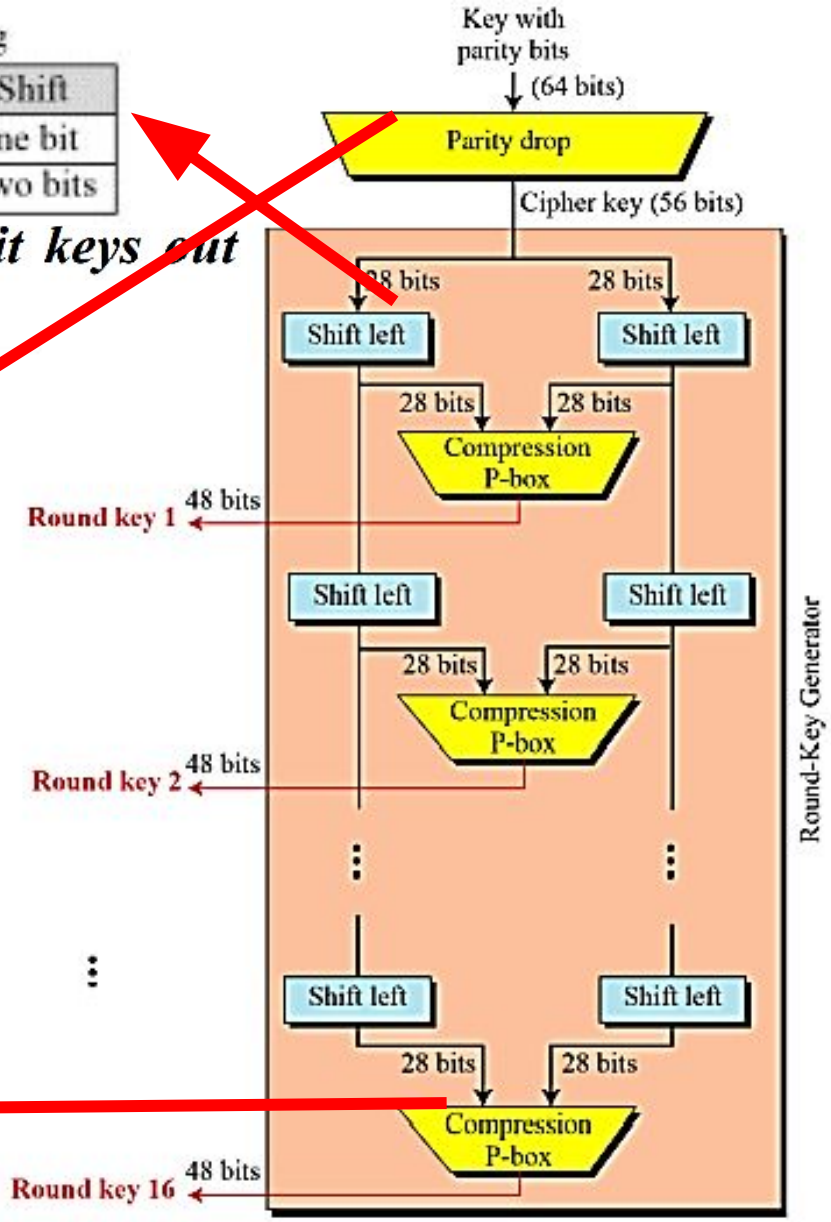


Figure 6.10
Key generation

Key Generation

The round-key generator creates sixteen 48-bit keys out of a 56-bit cipher key.

Shifting

Rounds	Shift
1, 2, 9, 16	one bit
Others	two bits

Steps:-

1. It drops the parity bits (bits 8, 16, 24, 32, 40,48,56, & 64) from the 64-bit key and permutes the rest of the bits according to Table 6.12
2. From this 56-bit key, a different 48-bit Sub Key is generated during each round using a process called key transformation
3. For this, the 56-bit key is divided into two halves, each of 28 bits.
4. These halves are circularly shifted left by one or two positions, depending on the round.
5. For example, if the round numbers 1, 2, 9, or 16 the shift is done by **only one position** for other rounds, **the circular shift is done by two positions.**

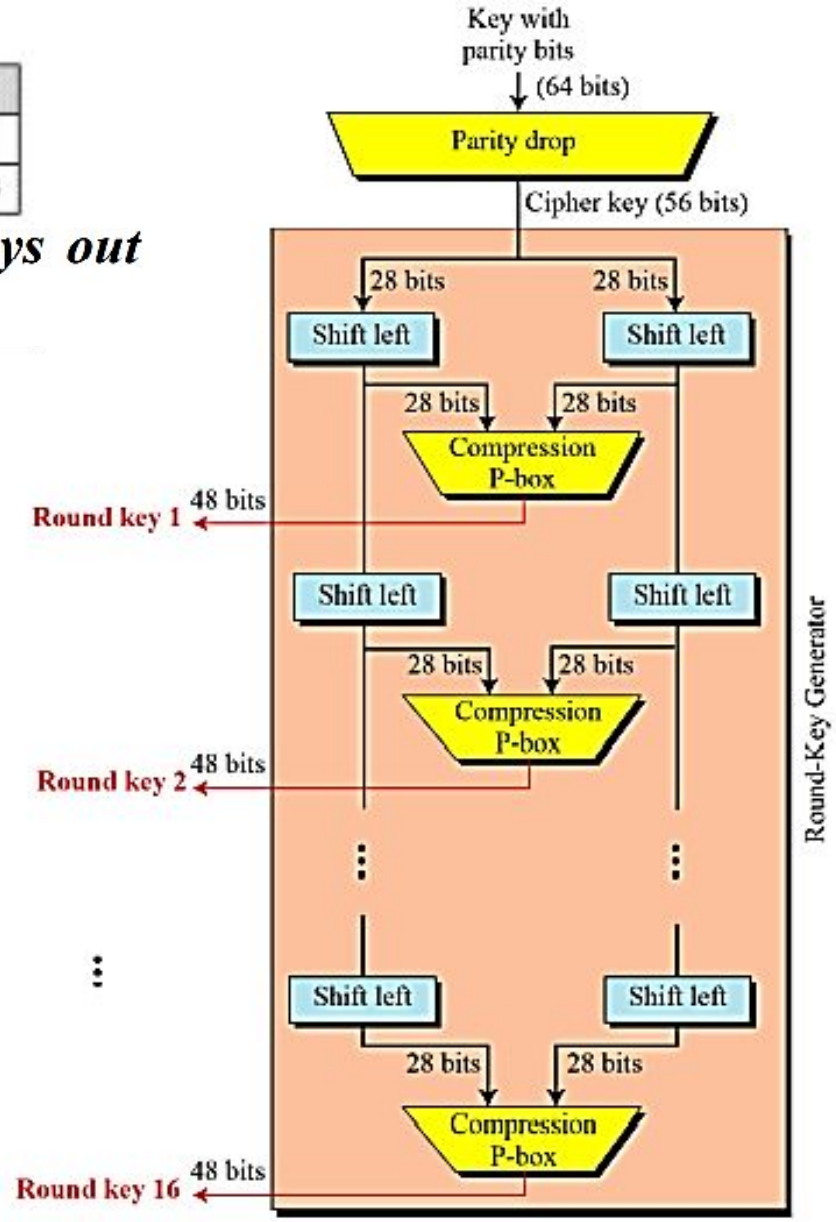
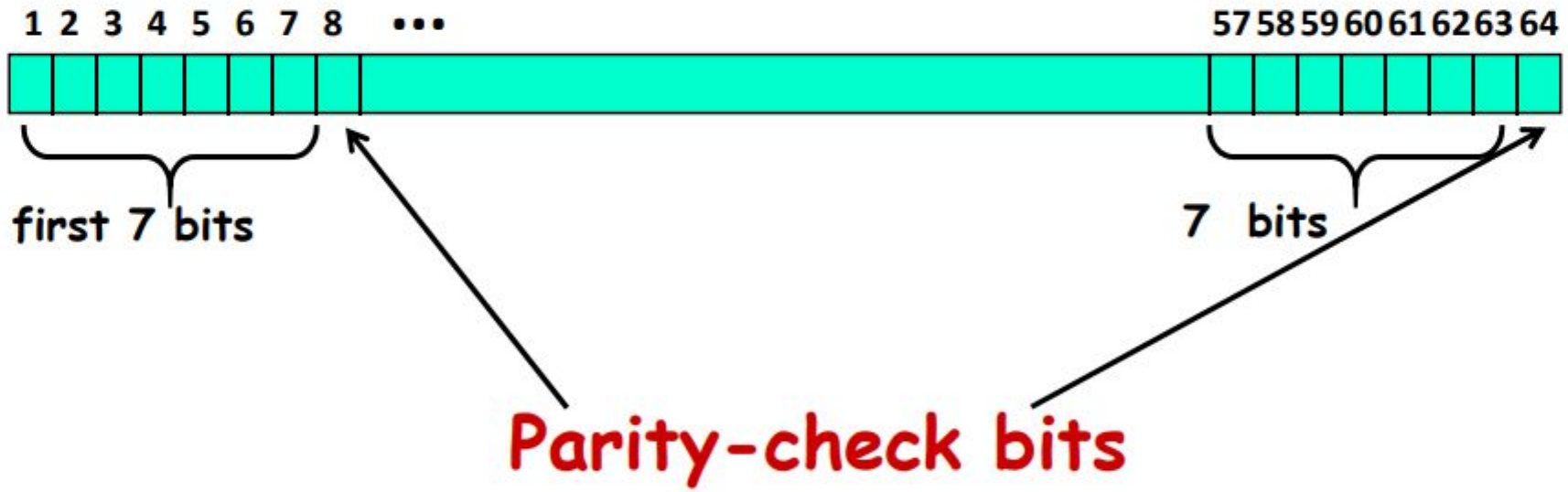


Figure 6.10
Key generation

Supplementary Slides

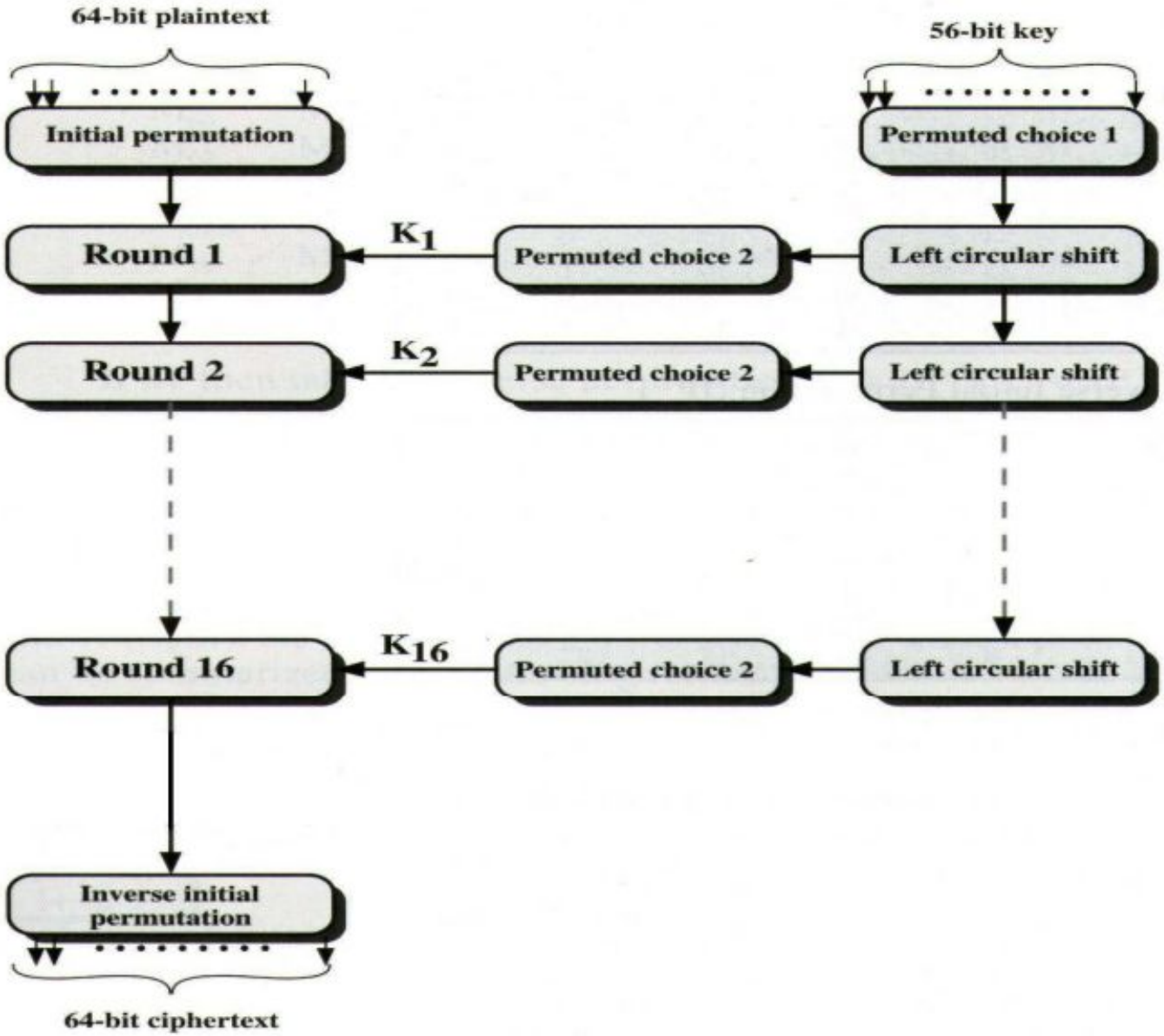
Key length in DES

- In the DES specification, the key length is 64 bit:
- 8 bytes; in each byte, the 8th bit is a parity-check bit



Each parity-check bit is the XOR of the previous 7 bits

DES Rounds


64-bit plaintext
56-bit key
Initial permutation
Permuted choice 1
Round 1
K1
Permuted choice 2
Left circular shift
Round 2
K2
Permuted choice 2
Left circular shift
Round 16
K16
Permuted choice 2
Left circular shift
Inverse initial permutation
64-bit ciphertext

Feistel/Block Cipher Structure

- **Reversible Transformation**
  - A block cipher operates on a PT block of n bits to produce a CT blocks
  - For encryption to be reversible or non-singular, each must produce a unique CT block

Reversible Mapping	
00	11
01	10
10	00
11	01

- **Irreversible Transformation**
  - For the encryption to be irreversible or singular (decryption is impossible) not all the PT block would have unique CT block

Reversible Mapping	
00	11
01	10
10	01
11	01

Feistel Cipher

- Symmetric block encryption algorithms are referred to as Feistel block cipher

- The concept is to have product cipher
  - Product Cipher

    It is the execution of two or more simple ciphers in sequence in such a way that the final result or product is cryptographically stronger than any of the component ciphers.

- Feistel proposed the use of a cipher that alternates **substitutions** and **permutations**

Substitutions

- Each plaintext element or group of elements is uniquely replaced by a corresponding ciphertext element or group of elements

Permutation

- No elements are added or deleted or replaced in the sequence, rather the order in which the elements appear in the sequence is changed

Feistel Cipher

- It is a practical application of a proposal by Claude Shannon to develop a product cipher
- It is the structure used by many significant symmetric block ciphers currently in use
- Shannon suggested two methods **for frustrating statistical cryptanalysis** e.g., human readable message frequency distribution, if reflects in the CT

- Two basic building blocks are
  - Confusion
  - Diffusion

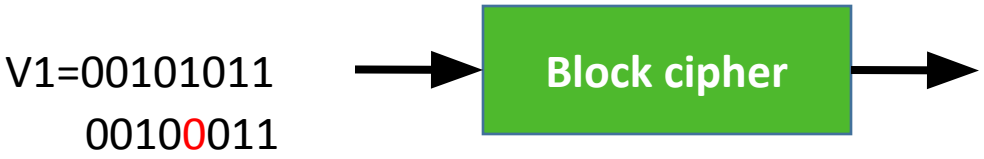
Confusion

- It is achieved through **XOR operation**, performed on PT and the encryption key
- It gets by the **use of a complex substitution algorithm**
- Seeks to make the relationship between the statistics of the ciphertext and the value of the encryption key as complex as possible
- This will frustrate the adversary who uses CT to find the key. In other words, if a single bit in the key is changed, most or all bit in the CT will also be changed.
- Even if the attacker can get some statistics of the CT, the way in which the key was used to produce that ciphertext is so complex as to make it difficult to deduce the key

Diffusion

- It is achieved through numerous permutations followed by applying a function to that permutation
- The statistical structure of the plaintext is dissipated into long-range statistics of the ciphertext
- This is achieved by having each plaintext digit affect the value of many ciphertext digits as if we change a character of the PT , then several characters of the CT should change

Example



Avalanche Effect

Confusion is apparently “enough” since OTP is secure. But diffusion alone is perhaps not enough at least using relatively small blocks

A substitution-permutation Network

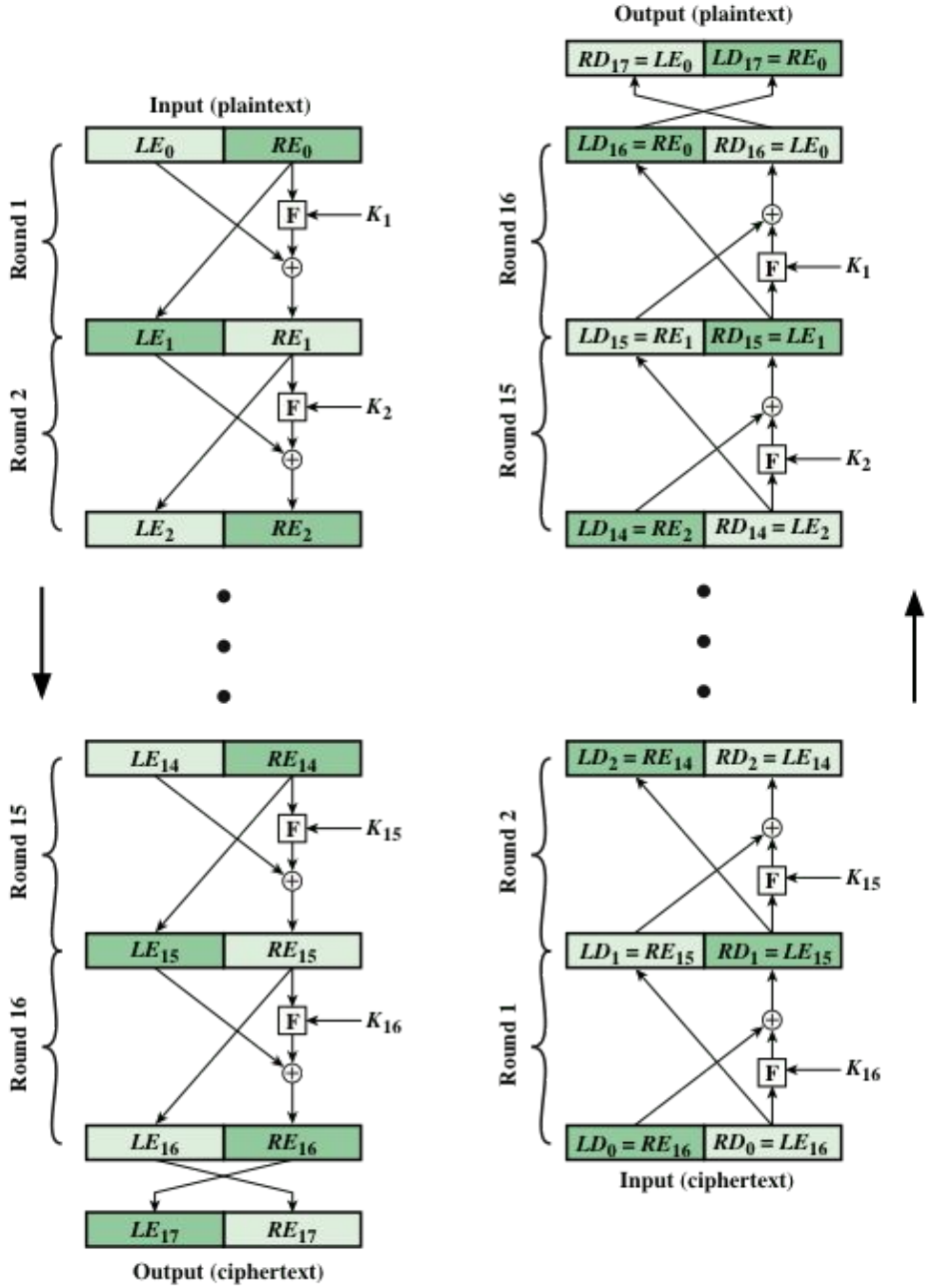


Figure 4.3 Feistel Encryption and Decryption (16 rounds)

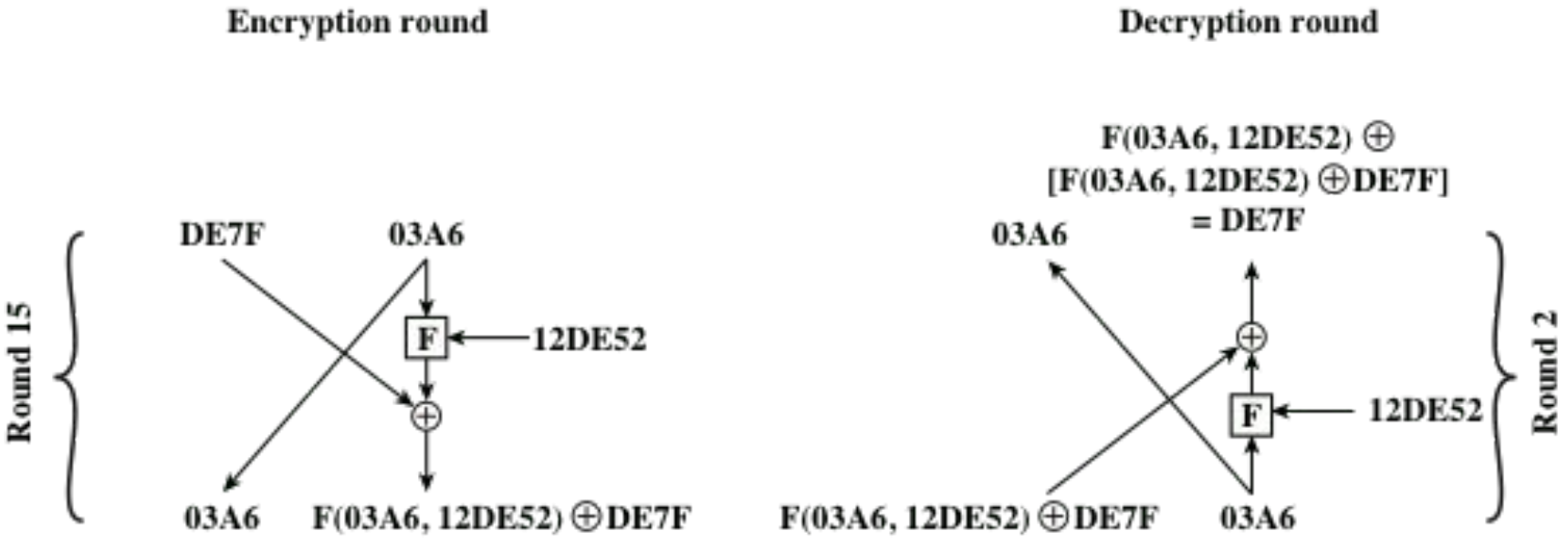
Feistel Cipher Design Features/Parameters

- **Block size**
  - Larger block sizes mean greater security but reduced encryption/decryption speed for a given algorithm
- **Key size**
  - Larger key size means greater security but may decrease encryption/decryption speeds (greater confusion & resistance to brute-force attack- now 128 bits key is common)
- **Number of rounds**
  - The essence of the Feistel cipher is that a single round offers inadequate security but that multiple rounds offer increasing security
- **Subkey generation algorithm**
  - Greater complexity in this algorithm should lead to greater difficulty of cryptanalysis

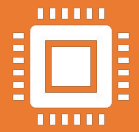
Feistel Cipher Design Features

- **Round function F**
  - Greater complexity generally means greater resistance to cryptanalysis (e.g., include S-boxes, permutation etc.)
- **Fast software encryption/decryption**
  - In many cases, encrypting is embedded in applications or utility functions in such a way as to preclude a hardware implementation; accordingly, the speed of execution of the algorithm becomes a concern
- **Ease of analysis**
  - If the algorithm can be concisely and clearly explained, it is easier to analyze that algorithm for cryptanalytic vulnerabilities and therefore develop a higher level of assurance as to its strength

Feistel Ciphers Mechanism (Example)



Why 16 Rounds?



The goal is to completely scramble the data and key so that every bit of CT depends on every bit of the data and key



After sufficient rounds, there should be no correlation between the CT and either PT or key

- Minimum of 12 rounds were needed to sufficiently scramble the key and data together (for confusion & diffusion)
- Secondly, the operation of 16 rounds would return the key back to its original position in the electronic device for the next round

Strength of DES



- Brute force attack is impractical with key length of 56 bits as there are 2^{56} possible keys or 7.2×10^{16} keys
- Strength can be increased by compression of the plaintext before encryption
- It becomes questionable since very powerful machines can do parallel bit of time to break ciphertext

Security provided by DES



- It depends on several factors
  - Mathematical Soundness
  - Length of Key
  - Key Management
  - Input data Formatting
  - Mode of Operation
  - Implementation

Block Cipher Principles: Number of Rounds

The greater the number of rounds, the more difficult it is to perform cryptanalysis

In general, the criterion should be that the number of rounds is chosen so that known cryptanalytic efforts require greater effort than a simple brute-force key search attack

If DES had 15 or fewer rounds, differential cryptanalysis would require less effort than a brute-force key search

Block Cipher Design Principles: Key Scheduling Algorithm

- With any Feistel block cipher, the key is used to generate one subkey for each round
- In general, we would like to select subkeys to maximize the difficulty of deducing individual subkeys and the difficulty of working back to the main key
- It is suggested that, at a minimum, the key schedule should guarantee key/ciphertext Strict Avalanche Criterion and Bit Independence Criterion